



Automated cybersecurity impact propagation across business processes using process mining techniques

Melina Raptaki¹ · George Stergiopoulos² · Dimitris Gritzalis¹

Accepted: 14 April 2025 / Published online: 16 May 2025
© The Author(s) 2025

Abstract

Business Impact Analysis (BIA) evaluates how cyberattacks affect essential business processes and IT assets. Traditionally conducted through manual interviews by consultants, this approach is often inefficient and prone to errors and omissions. In this paper, we present an automated methodology leveraging process mining to assess the impact of cybersecurity incidents on business processes. This methodology extracts event logs from information systems to construct business dependency graphs, quantify impact propagation across them, and integrate cybersecurity risk inputs from security officers. Tested on procurement workflows for an international transportation company, and compared with established baselines as well as the insight and knowledge of the company itself, our methodology proved to be effective at identifying risks stemming from a cybersecurity incident without significant labor, as well as uncovering high-risk paths that weren't yet identified, resulting in actionable insights. This is an extended and revised version of this methodology, evaluated with an extensive case study encompassing a company's BIA, historical data and expert opinion, first presented in Raptaki (IEEE Access 12: 194322–194339, 2024).

Keywords Cybersecurity · Cyberattacks · Business impact analysis · Impact propagation · Process mining

1 Introduction

Business Impact Analysis (BIA) is a critical element of IT risk management (and often required by critical or national operators or relevant standards like ISO 22301) that is widely used to assess the potential consequences of cybersecurity incidents and help organizations prioritize cybersecurity efforts by identifying vital assets and processes requiring heightened protection.

BIA considers various factors, including financial losses, operational disruptions, regulatory penalties, and reputational damage, to quantify the impact of security breaches. Current BIA standards start by identifying crucial business

processes and then delve into the associated systems and assets that underpin these processes [2–4]. However, the analysis predominantly focuses on information system assets, sidelining the intrinsic details of business processes which are mapped on high-level business process models that may not directly align with actual organizational workflows, leading to the omission of crucial contextual information and interdependencies.

In today's landscape, the study of business processes alongside their constituent activities, and interrelationships has gained significant research spotlight, particularly as organizations manage complex digital workflows [5–7]. Process mining, an emerging discipline, examines an organization's system logs to extract and model these processes [8]. Although research encourages the integration of business process management into risk management [9, 10] and vice versa [11, 12], process mining remains underutilized, with limited applications in cybersecurity [13, 14], and currently has no direct implementations for cybersecurity goals.

1.1 Motivation

Analyzing vulnerabilities across various business processes reveals a key insight. That is, that the examination of a Point

✉ Dimitris Gritzalis
dgrit@aueb.gr

Melina Raptaki
mraptaki@aueb.gr

George Stergiopoulos
g.stergiopoulos@aegean.gr

¹ Athens University of Economics and Business, Patission 76,
10434 Athens, Greece

² University of the Aegean, Lofos Panepistimiou, 81100
Mytilene, Greece

of Interest (POI) event from a business process perspective, showcases a complex network of activities stemming from it, the majority of which might not be mapped on an asset level, due to the numerous systems and actors involved. As such, critical activities might be overshadowed by a larger number of less significant steps. These non-essential connections, representing minor business events, far outnumber the critical ones. However, critical activities exhibit distinct characteristics—such as shared data formats, IT systems, or timestamps—that closely link them to the POI event.

Integrating process mining into Business Impact Analysis (BIA) can uncover valuable insights into potential cyberattacks, significantly streamline the creation of detailed impact assessments, and automatically provide cybersecurity-focused intelligence on the organization's information systems. By exposing the interdependencies among assets, which are often treated as isolated components, this approach enhances incident response strategies and strengthens risk management practices.

1.2 Contribution

In this paper, we expand upon the PProcess Impact Analysis (PRIA) tool, introduced in [1], designed to automatically identify critical business activities from event logs and evaluate their susceptibility to cyberattacks, aiding decision-makers in minimizing disruptions. PRIA employs process mining to: (i) extract business activity flows from ERP and CRM system logs, (ii) build graph models representing these processes and their interdependencies, (iii) use causality analysis and risk management principles to calculate exposure weights, and (iv) assess the criticality of data flows and IT asset vulnerabilities during cybersecurity incidents. The aim of this paper is, by expanding upon the original methodology and the framework of its implementation, to provide actionable insights into business and IT asset impacts, prioritizing risk mitigation efforts.

The contributions of this paper are:

- 1) **Impact Propagation Algorithm:** We adapt existing algorithms as well as the one already introduced in [1] to create an impact propagation method with unique capabilities:
 - a. It calculates forward impact propagation from a Point-of-Interest node in a multigraph, unlike simpler graph structures.
 - b. It operates on graphs with closed circuits, ensuring accurate impact assessments without amplifying effects due to back-propagation in loops.
 - c. It can be applied to subgraphs to account for loss of availability of subsets of activities within the flows.

- 2) **Risk Management:** Our methodology generates prioritized rankings of business activities and their associated IT assets, enabling organizations to manage risks and minimize disruptions during cybersecurity incidents. In this paper, we enacted a comprehensive framework of implementing and evaluating it within an organization, specifically a company based in Greece dealing with the transportation of goods operating across the world, benchmarking its results against existing assessments and expert knowledge (gathered via interviews), and enacting specific policies and changes based on the insights produced.

1.3 Evaluation

The absence of methods in literature with a similar premise, to the best of our knowledge, renders it impossible to evaluate this methodology using such benchmarks. As such, the evaluation process is more complex, in order to adequately assess our findings, consisting of the following aspects:

- 1) Comparison with the results rendered from approaches in literature that can be considered as baselines for our own, so that we can adequately assess whether this approach is a marked improvement upon them, and highlight its unique contributions to impact analysis, and
- 2) Comparison with the results of a BIA undertaken using traditional approaches, leveraging the experience of a real-world organization case study to verify whether the results presented in this paper are accurate and offer additional insights not usually uncovered.

To achieve this, we utilized a dataset comprising event logs extracted from the information systems of a goods transportation company. Various cybersecurity incidents and their potential repercussions were modeled using this data. The dataset includes over 500,000 events related to the procurement process, derived from more than 3 million records. The evaluation involved three sets of interviews with five company employees representing diverse roles in IT, Business Process Management, and Risk Management.

1.4 Structure

The rest of this paper is organized as follows: Section 2 presents related work for this methodology, especially concerning business impact analysis, process mining and its application in cybersecurity. Section 3 presents in detail the proposed methodology. Section 4 presents the case study undertaken for the evaluation of this methodology. Section 5 presents the results and takeaways of the evaluation. Finally,

Section 6 discusses the conclusions and potential future research.

2 Related work

The presented methodology leverages concepts and ideas from various fields, namely business impact analysis, process mining for cybersecurity and tools for the automation of log analysis. Relevant literature is presented for those in the following paragraphs.

2.1 Impact analysis

Numerous methodologies and tools have been developed to conduct business impact analyses and quantify the effects of cybersecurity breaches, with the goal of mitigating risks and ensuring organizational resilience. These approaches aim to maintain business continuity during breaches while supporting risk assessment processes that rely on evaluating the impact on critical assets [15].

Traditional methods focus on identifying an organization's essential business processes and linking them to IT assets (e.g., servers, systems, databases) to assess the consequences of compromised confidentiality, integrity, or availability [16]. His process typically involves gathering input from organizational experts through interviews, questionnaires, and workshops [17–19]. While effective in leveraging expert knowledge, these methods are often labor-intensive, time-consuming, and prone to inaccuracies, while there is limited attention to cascading effects.

As a result, automating business impact analysis has become a priority, leading to innovative approaches. Research in particular emphasizes the need for holistic organizational models to better capture these dependencies from a cybersecurity perspective [20, 21]. However, many automation efforts only partially address the data collection phase, instead offering tools to streamline the process or provide a more structured starting point [22, 23]. Other approaches assume the existence of predefined business process models and focus on automating the impact analysis based on these models [24, 25].

Graphs and transition diagrams are emerging as preferred tools to represent interdependencies, ranging from hardware components to business processes, and to evaluate the cascading effects of risks across these interconnected systems. This approach is being applied across various domains, including change management [26], risk mitigation [27] and risk assessment [14, 28]. Additionally, there is growing interest in modeling cascade effects using propagation mechanisms within such graphs [29, 30], and causality analysis has been highlighted as a valuable tool for understanding impact propagation through sequences of activities [31, 32].

2.2 Process mining for cybersecurity

Process mining has gained significant traction in cybersecurity over recent years, with numerous approaches utilizing its principles to address existing challenges in innovative and efficient ways. Though outside the primary focus of this study, process mining has been successfully applied in areas such as intrusion detection and anomaly identification [33–36], auditing [37], forensic analysis [38] and even cybersecurity training [39]. The emergence of new technologies and the resulting complexities introduced also have created an interesting field of application of process mining in the context of their security [40, 41]. These applications often adapt process mining algorithms to cybersecurity use cases with promising outcomes. However, apart from training, most implementations do not target business processes directly.

In the context of Business Impact Analysis (BIA), process mining has the potential to address two critical elements: identifying business processes and mapping their interdependencies. Using event logs generated by an organization's information systems, process mining can automatically uncover and model actual workflows, capturing the flow of activities and transitions within business processes [42]. Research has increasingly explored the integration of process mining with risk management methodologies. For instance, process mining has been used to analyze anomalous behavior and extreme events for risk assessment [13], and to associate risks with conformance analysis [43]. Furthermore, there is growing interest in enhancing process mining techniques with security-specific annotations and information [44–47]. Despite this progress, no existing work has applied process mining to automate BIA or to model impact propagation across interconnected business processes to the best of our knowledge.

2.3 Building blocks

Based on the above, our process-aware business impact analysis methodology previously introduced in [1], leverages multiple methods to discover, analyze and assess business processes. More specifically, we utilized concepts and methods from:

1. The field of process mining, in order to automatically discover the business processes and their internal structure [8] and
2. Existing research into the propagation of impact of cybersecurity incidents across graphs [48]
3. Existing tools for the automation of log analysis, such as ProM [49], and their application to cybersecurity problems.

The combination of the above aim to showcase how the effects of a cybersecurity incidents can propagate across an entire business process and offer insights as to the necessary prioritization of assets for effective risk mitigation.

3 Presentation of the methodology

This section showcases the design of our methodology, divided in three distinct phases (Section 3.1), as well as the expected inputs and outputs of the methodology (Section 3.2). Additionally, the threat model for which it is applicable is presented in Section 3.3.

3.1 Design

Our methodology operates in three phases: (i) extracting business activities from event logs, (ii) assigning weights to mined transitions and ranking transitions, and (iii) calculating dependency impacts using a mathematical algorithm to model cybersecurity incident propagation using input from the organisation's security plan.

In *Phase 1*, business processes are mined from event logs in systems such as ERP or CRM, adhering to the XES standard for process mining algorithms [50]. The result is a process dependency graph that encompasses activities, transitions, and dependencies, with a focus on causal relationships to identify how one activity impacts another [51–53].

Phase 2 involves quantifying dependencies between activities by assigning weights to transitions in the graph. These weights, first presented in [1], prioritize paths that indicate a higher propagation of impact, measuring features including causality, diffusion and flow rate, while normalization is also applied to ensure the nature of the graph with closed loops won't result in nodes with higher calculated dependency impact than the one initially targeted.

An expansion was introduced in this phase compared to the original methodology (PRIA), with *the graph dynamically adjusted to reflect changes in asset availability*, ensuring accurate impact propagation modeling. In the case that the users have recorded the loss of availability of specific assets and/or systems, then the list of relevant activities is taken into account. In such scenarios, our methodology recalculates the weights for the subgraph resulting from the available activities, and proceeds with the impact analysis phase for both iterations of the graph, so as to better understand both the potential impact of the initial attack, as well as the ramifications to the BIA in an altered landscape.

In *Phase 3*, the impact of a cybersecurity incident is modeled, starting from a designated point-of-interest (POI) activity. Using dependency weights from Phase 2, it calculates how the incident propagates across the process dependency graph and ranks activities by their criticality.

The activity associated with the POI event gets the maximum theoretical possible impact, which is set to 1, and for each subsequent node, the dependency impact is calculated as the sum of the impact of each of its parent nodes, multiplied by the edge's weight where DI_v represents the (dependency) impact of node v and $W_{e(u,v)}$ represents the dependency weight, after normalization, of edge $e(u, v)$:

$$DI_v = \sum_{u \in \text{parentNodes}(u)} DI_u * W_{e(u,v)} \quad (1)$$

Applied iteratively by updating each time the impact for each node, we achieve the propagation of the impact of the POI event across the graph, as shown in Algorithm 1.

Activities with an impact score above 0.5, indicating significant business process disruption, are prioritized for mitigation. For subgraph scenarios due to asset unavailability, the new POI is the activity with the highest remaining impact. These automated insights enable targeted risk management and mitigation strategies.

3.2 Input and output

The presented methodology accepts as input any dataset of event logs that is presented in XES format [54], with no other limitations (Fig. 1).

The results of the impact analysis are exported in two formats:

1. A CSV file containing all the activities documented, along with their dependency impact and whether they are considered critical
2. A JSON file where the entirety of the graph is documented, including the nodes, the edges, the weights of the edges, and the dependency impact of the nodes.

3.3 Threat model

Our threat model assumes an external attacker targeting the organization's assets without prior authorization to access its systems. The attacker may exploit system vulnerabilities or deceive users into executing malicious payloads. The case studies we conducted align with these assumptions. We also assume that the organization employs hardening techniques to secure the event logs of its systems, given their sensitivity and primary role in auditing. Consequently, attacks that directly compromise the security of these audit logs fall outside the scope of our model.

While the current threat model is deliberately constrained, our methodology has the potential to accommodate additional threat scenarios with further validation and research.

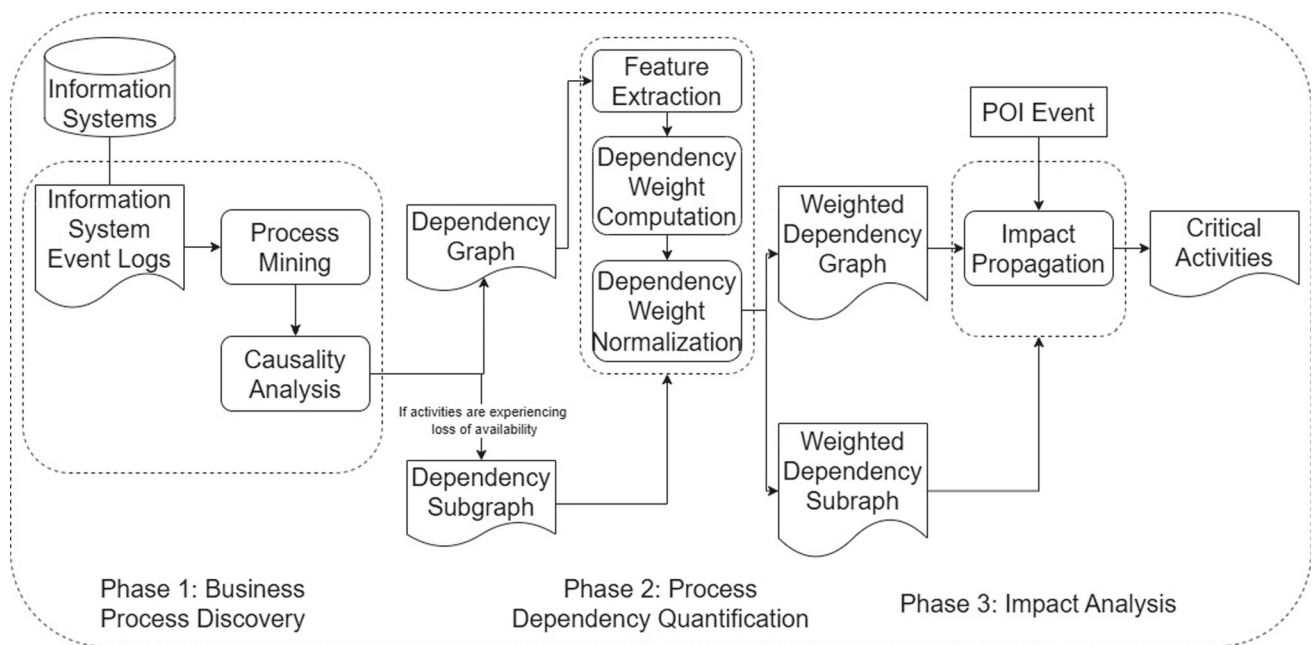


Fig. 1 The architecture of the presented methodology for process mining and impact analysis

This is because the impact propagation algorithm is agnostic to the attacker's identity or intent, focusing solely on the initial entry point of the attack. Potential extensions include:

1. **Insider Breaches:** Malicious insiders, such as employees with harmful intent, could act in ways that align with the presented methodology's capabilities, especially if they target systems generating logs that are compatible with the expected input.
2. **Unauthorized access/Unauthorized privilege escalation:** If an external attacker successfully gains access and/or even manages to escalate their privileges, this methodology could still evaluate the resulting impact propagation, assuming the breach has been identified. Future iterations might include parameters to account for the attacker's elevated privilege levels.
3. **Supply Chain Attacks:** An attack originating from compromised third-party software or services used by the organization also falls within our scope. In this scenario, the analysis would resemble the use case in this study if the attacker's point of entry was through a third-party tool that is part of the business processes of the organization.
4. **Advanced Persistent Threat or Multistage Attack:** While not useful for detecting such attacks, this methodology can be useful in modeling the impact analysis of various scenarios, so appropriate hardening techniques and countermeasures can be applied in critical infrastructures and processes.

Additionally, it should be noted that our threat model does not require that the attack concerns an already documented process, which is a strength derived by the reliance on process mining to generate the process graphs. However, in the event this methodology is used on an undocumented process, it won't be possible to validate the results against the already established process models, thus expert opinion will be the only available option for validation.

Lastly, we assume the initial point of attack impacts an asset associated with a business process or activity recorded in system logs. For instance, attacks that initially compromise personal workspaces or offline activities unconnected to the system's event logs would not be modeled. However, once the attack transitions to assets tied to logged activities, our methodology could then model the incident with the infected asset serving as the new point of entry.

4 Case study presentation

To validate this methodology, it was applied to a dataset extracted from the information systems of a real-world organization, the details of which are presented in the following paragraphs.

4.1 Tool implementation

For the process mining component of our methodology, we chose ProM as the primary tool, utilizing the binaries from its

latest stable version, 6.12. ProM (2023) is a versatile, open-source platform that has become a cornerstone in the field of process mining. It provides robust capabilities for analyzing, visualizing, and extracting insights from event logs generated by business processes. Originally developed in 2005 at Eindhoven University of Technology's Department of Technology Management [49], ProM has undergone continuous updates and feature enhancements over the years [55].

One of ProM's key strengths lies in its modular, "plug-gable" architecture, which allows for extensive customization and expansion. Users can integrate a wide range of plugins tailored to various stages of process mining, such as importing and transforming event logs, applying mining algorithms, and exporting results or visualizations [56]. These plugins can be independently developed, added, or removed from the ProM framework, making it easy to tailor the tool to specific research requirements, as in this case.

In our implementation, we used the ProM Framework along with the following plugins:

1. The Import plugin [57] to load event logs into the system,
2. The Discover Graph plugin [58] to create a business process model through causality analysis.

These plugins were incorporated as binaries into a custom Java application, where they were modified to align with our methodology. The Java application handled the complete workflow, from parsing the event logs to generating the causality graph and performing impact calculations (Fig. 2).

The resulting tool was developed as a stand-alone, desktop-optimized application with user-friendly features. It supports XES-compliant log files as input, leveraging the ProM Import plugin, and includes additional functionality such as handling large event logs in compressed formats. After processing, the application exports results in multiple formats, including JSON for integration with other tools and CSV for direct analysis of key findings.

4.2 Dataset

The dataset was extracted from the information systems of a supply chain company, with its main activity being transportation of goods. The processes recorded within the data pertain to:

1. Purchase requisition,
2. Gathering quotes from suppliers,
3. Purchase ordering,
4. Receiving goods and,
5. Invoicing

The event log files in this dataset adhere to the IEEE-XES standard and maintain the conventional structure typically found in ERP system data.

The dataset for this case study pertains to the procurement process, and specifically contains orders filed through an ERP and all the preceding and subsequent documents for the entirety of the year 2023. It contains 553.763 events consisting of 3.565.326 records, with both identifying and transactional variables recorded for each (including data such as activity, resource, timestamp and process-related data). For each order, its entire lifecycle has been recorded in the dataset, from the registering of a requisition pertaining to certain needs, all through the issuing of the invoice.

It should be noted that, while the system logs of the ERP are used as the source, in the procurement process there are in total four systems involved, with changes logged into them being consequently logged into the ERP system. Those include, apart from the ERP (system A):

1. A Materials and Warehouse Management Solution (system B), used for logging purchase requisitions, hosted in public cloud.
2. A Procurement platform (system C), used by suppliers to provide quotes, hosted in public cloud.
3. An Invoice processing solution (system D), used by the company's own users to register invoices, hosted within the company's own network.

The activities in the dataset follow a naming convention that denotes the source system. Additionally, it should be noted that the activities in the dataset also contain cases of automated steps. The homogeneity of this dataset for a specific process allows for process mining to be applied on its entirety.

With the application of process mining techniques on this dataset, 30 distinct activities were identified over 110.275 different process instances (orders), performed by 108 distinct users, of which two are used for background processing, and the rest are regular users, employed by the company and involved with the procurement process (see Table 1).

4.3 Case study

In this section, we implement the presented methodology over the company dataset. The case study aims to showcase the valuable insights produced in the case of a specific cybersecurity incident. The case study was chosen because a disruption in the procurement process can be harmful to the organization's revenue and reputation, given the cascade effects on managing and scheduling its fleet, as well as the sensitive data handled, including supplier master data and invoicing details.

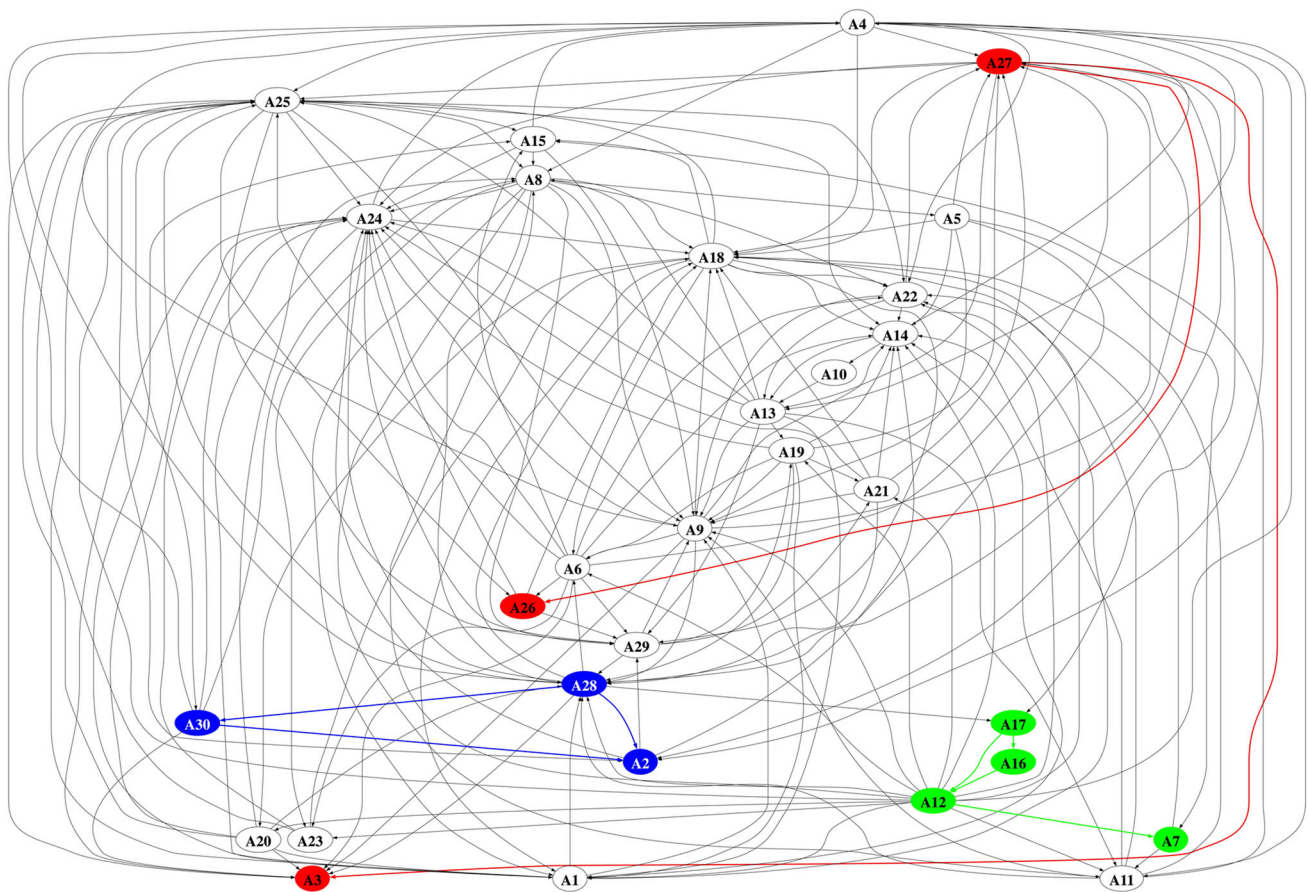


Fig. 2 The most critical paths for each attack based on the node ranking produced by the presented methodology. The activities here are depicted with the IDs assigned to them in Table 1

For this purpose, we will showcase the results from two distinct cases affecting this process.

- The first case is a *ransomware attack* that affected the Materials and Warehouse Management Solution (System B) in August 2023, that gets identified due to the loss of availability and a corresponding message in the application that is used to create Purchase Requisitions. In this case, a loss of availability was recorded in System B, and as such the relevant activities were flagged.
- The second case concerns the **invoicing sub-process**. Currently the company is considering the introduction of an online invoice registration solution, where the vendors would register their invoices and those would be automatically recorded in the ERP. However, there are security concerns due to the sensitivity of the process. As such, we were requested to investigate the potential consequences of an attack stemming from the registration of a supplier invoice or debit memo in the current landscape, to evaluate against their own analysis and facilitate a decision.

In each case, the attack could have significant repercussions to the company's reputation and profits, given the sensitive data handled and volatility of the transportation of goods within the supply chain. After analyzing each case, the sensitivity of the data involved and the importance of the process to the company, we set the threshold to flag an activity as having a high dependency impact at 50%, as such an activity will be deemed as critical if more than 50% of each capability to deliver output to the company flow is compromised. Consequently, the aim is to assess how each attack will impact the rest of the activities observed in the procurement process.

4.3.1 Case 1: ransomware in system B

The initial attack in question involves ransomware, which impacted the systems of the company offering the solution denoted as System B. Consequently, the Point of Interest (POI) event in our methodology is "B_Create Purchase Requisition".

The tool applies PRIA's algorithm [1], successfully completing after 1996 iterations with a low delta, taking 66 seconds to execute. Node ranking results are presented in

Table 1 Activities identified in Phase 1 as steps in the procurement process documented by the dataset

Activity	ID
A_Cancel Goods Receipt	A1
A_Cancel Invoice Receipt	A2
A_Cancel Subsequent Invoice	A3
A_Change Approval for Purchase Order	A4
A_Change Order Currency	A5
A_Register Order Delivery	A6
A_Change Order Payment Terms	A7
A_Change Order Price	A8
A_Change Order Quantity	A9
A_Reject Order	A10
A_Change Order Storage Location	A11
A_Create Purchase Order	A12
A_Create Request for Quotation	A13
A_Delete Purchase Order	A14
A_Release Purchase Order	A15
A_Release Purchase Requisition	A16
B_Create Purchase Requisition	A17
B_Record Goods Receipt	A18
C_Receive Order Confirmation	A19
C_Record Quotation	A20
C_Update Order Confirmation	A21
D_Block Supplier Invoice	A22
D_Block subsequent invoices	A23
D_Clear Invoice	A24
D_Record Invoice Receipt	A25
D_Record Subsequent Invoice	A26
D_Register supplier debit memo	A27
D_Register supplier invoice	A28
D_Remove Payment Block	A29
D_Set Payment Block	A30

Table 2 Ranking of activities based on calculated dependency impact, with activity “B_Create Purchase Requisition” as POI event

Activity	Dependency Impact
B_Create Purchase Requisition	1
A_Release Purchase Requisition	0,8356
A_Create Purchase Order	0,7472
A_Change Order Payment Terms	0,5523
A_Change Order Storage Location	0,519
C_Update Order Confirmation	0,5001
C_Receive Order Confirmation	0,4996
A_Change Order Quantity	0,4542
A_Change Approval for Purchase Order	0,4497
D_Block Supplier Invoice	0,4461
A_Register Order Delivery	0,4327
A_Delete Purchase Order	0,4272
A_Cancel Goods Receipt	0,427
D_Block subsequent invoices	0,4223
A_Change Order Price	0,4135
C_Record Quotation	0,4125
B_Record Goods Receipt	0,4062
A_Reject Order	0,3969
A_Create Request for Quotation	0,3927
A_Release Purchase Order	0,392
D_Register supplier debit memo	0,3855
A_Change Order Currency	0,3827
D_Register supplier invoice	0,3782
D_Record Invoice Receipt	0,375
A_Cancel Subsequent Invoice	0,3683
D_Record Subsequent Invoice	0,3634
A_Cancel Invoice Receipt	0,3592
D_Clear Invoice	0,3589
D_Remove Payment Block	0,3473
D_Set Payment Block	0,3446

Table 2. In general, a limited amount of nodes exhibit a significant dependency impact, with 20% automatically flagged as critical due to a dependency impact exceeding 0.5.

Given this case results in the loss of availability of System B, the following activities were flagged to be no longer available and thus directly relevant to the ranking: A17, A18. This generated a subgraph where the POI event was considered to be activity A16 (A_Release Purchase Requisition), as the highest ranked available activity in the original graph. The results of impact propagation based on this POI event and the weights calculated over the subgraph are presented in Table 3.

The tool applies the algorithm on the subgraph, successfully completing after 1674 iterations with a low delta, taking

63 seconds to execute. In this case, more nodes exhibit a significant dependency impact, with 28,6% automatically flagged as critical due to a dependency impact exceeding 0.5.

4.3.2 Case 2: compromise of the invoicing subprocess

The second case concerns investigating two hypothetical attacks, setting as POI event the activities “D_Register supplier invoice” and “D_Register supplier debit memo”. The aim is to understand the potential ramifications of an attack impacting those activities, in light of the company’s intention to relocate those activities to a new, public cloud provider. The tool implements the algorithm from Section 4.3, which

Table 3 Ranking of activities based on calculated dependency impact, with activity “A_Release Purchase Requisition” as POI event on the subgraph without System B

Activity	Dependency Impact
A_Release Purchase Requisition	1
A_Create Purchase Order	1
A_Change Order Payment Terms	0,6803
C_Update Order Confirmation	0,6403
A_Change Order Quantity	0,6366
A_Change Order Storage Location	0,619
C_Receive Order Confirmation	0,5936
A_Register Order Delivery	0,5896
C_Record Quotation	0,478
A_Change Order Price	0,4467
A_Delete Purchase Order	0,4465
A_Change Approval for Purchase Order	0,431
A_Cancel Goods Receipt	0,4265
D_Block Supplier Invoice	0,4211
A_Reject Order	0,3945
A_Cancel Invoice Receipt	0,3816
D_Clear Invoice	0,3789
D_Register supplier debit memo	0,3643
D_Record Subsequent Invoice	0,3634
A_Change Order Currency	0,3509
A_Cancel Subsequent Invoice	0,349
D_Register supplier invoice	0,3342
D_Set Payment Block	0,3184
D_Block subsequent invoices	0,3022
D_Remove Payment Block	0,3021
A_Create Request for Quotation	0,2627
D_Record Invoice Receipt	0,174
A_Release Purchase Order	0,134

terminated successfully after 1281 iterations with a low delta value, taking 53 seconds to run for “D_Register supplier invoice” and which terminated successfully after 1456 iterations with a low delta value, taking 58 seconds to run for “D_Register supplier debit memo”.

In the case of “D_Register supplier invoice” (node ranking results can be found in Table 4), our methodology suggests focusing on protecting invoice related activities as top priorities. *Approximately 33% of activities were automatically flagged as critical, though it should be noted that most are closer to the 50% dependency impact threshold.*

In the case of “D_Register supplier invoice” (node ranking results can be found in Table 5), our methodology suggests focusing on protecting activities related to subsequent invoices as top priorities. *Approximately 13% of activities*

Table 4 Ranking of activities based on calculated dependency impact, with activity “D_Register supplier invoice” as POI event

Activity	Dependency Impact
D_Register supplier invoice	1
D_Set Payment Block	0,6925
A_Cancel Invoice Receipt	0,6767
B_Create Purchase Requisition	0,6444
A_Release Purchase Requisition	0,6434
A_Create Purchase Order	0,6189
A_Change Approval for Purchase Order	0,5529
A_Change Order Storage Location	0,5153
A_Change Order Payment Terms	0,5131
A_Cancel Subsequent Invoice	0,5038
C_Receive Order Confirmation	0,3835
A_Change Order Price	0,3799
C_Update Order Confirmation	0,3772
D_Record Invoice Receipt	0,3743
D_Block Supplier Invoice	0,3724
A_Change Order Quantity	0,3637
A_Delete Purchase Order	0,3585
D_Register supplier debit memo	0,3526
A_Register Order Delivery	0,3513
A_Change Order Currency	0,3506
A_Create Request for Quotation	0,346
D_Clear Invoice	0,3429
B_Record Goods Receipt	0,3408
D_Block subsequent invoices	0,3397
A_Cancel Goods Receipt	0,3346
D_Record Subsequent Invoice	0,3306
A_Release Purchase Order	0,3305
D_Remove Payment Block	0,3281
A_Reject Order	0,3267
C_Record Quotation	0,3185

were automatically flagged as critical, most close to the 50% dependency impact threshold.

5 Evaluation

In this Section, the results of the evaluation of the case study will be presented in detail. After introducing the specific aspects of the Evaluation Setup (Paragraph 5.1),

5.1 Evaluation setup

The tool was deployed on a personal computer with an Intel® Core™ i5-5250U Processor (3M Cache, up to 2.70 GHz),

Table 5 Ranking of activities based on calculated dependency impact, with activity “D_Register supplier debit memo” as POI event

Activity	Dependency Impact
D_Register supplier debit memo	1
D_Record Subsequent Invoice	0,5832
A_Cancel Subsequent Invoice	0,5666
B_Create Purchase Requisition	0,5117
A_Cancel Invoice Receipt	0,4886
A_Create Purchase Order	0,4349
A_Create Request for Quotation	0,4286
A_Release Purchase Requisition	0,4204
C_Receive Order Confirmation	0,384
C_Update Order Confirmation	0,3589
A_Change Order Storage Location	0,343
A_Change Order Payment Terms	0,3355
D_Remove Payment Block	0,326
A_Delete Purchase Order	0,3136
A_Cancel Goods Receipt	0,31
B_Record Goods Receipt	0,3093
A_Change Order Quantity	0,307
D_Clear Invoice	0,304
D_Record Invoice Receipt	0,3032
A_Change Order Price	0,302
D_Block Supplier Invoice	0,2997
A_Change Approval for Purchase Order	0,2982
A_Register Order Delivery	0,2935
A_Reject Order	0,2869
A_Release Purchase Order	0,2846
D_Block subsequent invoices	0,2819
A_Change Order Currency	0,2757
C_Record Quotation	0,2709
D_Register supplier invoice	0,2657
D_Set Payment Block	0,2596

with 8 GB RAM, running macOS Monterey version 12.6.3. As such, the performance exhibited follows the constraints of its deployment on a personal computer.

The dataset compiled for the evaluation is presented in detail in the following Section. While we couldn't extract the totality of the company's event logs for a given time period due to various concerns, the dataset's size and attributes reflect a real-world example, given it covers an entire year of events in a specific process.

In order to validate our results, we had the following assets at our disposal:

1. The company's own process models and Business Impact Analyses.

2. The insights of five employees within the company, with the following roles:

- a. ERP Technical Administrator
- b. IT Applications Head
- c. Cybersecurity Officer
- d. Business Process Manager
- e. Procurement Officer

In evaluating the tool with this dataset, we aim to answer the following questions:

1. How effective is this methodology at identifying critical activities for risk mitigation?
2. Do the insights gleaned make sense in the context of the business process under examination?
3. Does the methodology provide insights not readily available through traditional approaches?

5.2 Interviews

To assess the performance and validate the results of our methodology, a structured interview process was conducted with relevant stakeholders in the company where the methodology was applied. These interviews were designed to evaluate its ability to identify critical activities for risk mitigation, its relevance to actual business processes, and the additional value it provides compared to traditional approaches.

5.2.1 Interview framework

The evaluation involved three sets of interviews:

1. **Pre-Implementation Discussions:** Stakeholders were introduced to the methodology, its objectives, and operational principles. These discussions allowed for a comparison with the organization's existing Business Impact Analysis (BIA) practices and provided context for understanding its outputs.
2. **Case-Specific Follow-Up Interviews:** After applying the presented methodology to two separate cases, presented in Sect. 4.3, follow-up interviews were conducted to present and validate its results. Stakeholders reviewed the dependency graphs, critical activity rankings, and propagated impact assessments generated. Additionally, the stakeholders were presented with alternate results as baselines (described in Sect. 5.3), to assess our output against those of methodologies similar to it.

5.2.2 Resources for validation

The validation process leveraged the following resources:

- **Company Artifacts:** Process models and prior BIA documentation were used to benchmark our findings.
- **Expert Insights:** Feedback was gathered from five employees representing key roles:
 - o ERP Technical Administrator
 - o IT Applications Head
 - o Cybersecurity Officer
 - o Business Process Manager
 - o Procurement Officer

5.2.3 Interview structure

For the follow-up to each case, the following questions was asked to each stakeholder, after the presentation of the case and the relevant findings:

1. How serious do you expect/know the impact of the described attack to be? Which processes do you expect will be impacted the most?
2. What is your assessment of the presented ranking?
3. Does this ranking align with expectations? How do you assess any divergence?
4. Would you adopt this ranking for risk mitigation?
5. Are there any actions and/or changes you would consider based on those findings?
6. What differences do you identify between this ranking and the existing strategy? How do you assess any differences identified?

The above were followed by a round table with all experts, where the respective insights were discussed and dissected, and potential changes were discussed.

5.3 Evaluation results

The results of the evaluation process, as they emerged from the interviews, comparisons, and the process of execution, are presented in the following paragraphs.

5.3.1 Insights and actions

The application of our methodology to two distinct cases revealed significant insights, which were validated through expert interviews and comparisons with the company's existing Business Impact Analysis (BIA) processes. The insights were discussed in the interview process, resulting in specific

Table 6 Summary of actions and changes that resulted from the methodology's application process

Case	Insight	Action
1	POI activity in system B, high ranking in system A	Adjust mitigation measures to take into account tightly coupled activities in different systems
1	Divergence from expected sequence of activities	Implementation of safeguards to ensure processes are adhered to
1	Divergence from expected sequence of activities	Additional trainings to users
1	Low ranking of activities that are regarded as high priority in the process (e.g. invoicing)	Reassessment of mitigation strategy
1	Low ranking of activities that are regarded as high priority in the process (e.g. invoicing)	Implementation of measures for the option of easier decoupling of systems
1	High ranking of activities in System C in the revised ranking excluding the unavailable system	Introduction of measures for risk mitigation concerning downstream systems that weren't considered easily impacted
2	Low ranking of separate subprocesses even for activities within the impacted system	Reassessment of mitigation strategy to take into account both system and process
2	High ranking of activities in the start of the process (e.g. Create Purchase Requisition) when the impacted activity is towards the end (e.g. Invoicing)	Further examination of how the process is enacted by users
2	High ranking of activities in the start of the process (e.g. Create Purchase Requisition) when the impacted activity is towards the end (e.g. Invoicing)	Design of changes to the guidelines to ensure less overlap between the end of the process and the start of a new one

actions to be implemented and changes to be made, which are summarized in Table 6.

In the first case study, our outputs aligned closely with expectations, as it ranked activities intuitively connected to the most impacted activity—Purchase Requisition—as highly critical. Activities that were less tied to the affected part of the process, such as Invoicing, received lower rankings, reflecting their peripheral role in the procurement process. However, data-driven insights that challenged stakeholder assumptions were also uncovered. For instance, while

Quotation Creation was expected to rank higher due to its immediate connection to the requisition, *its lower ranking revealed a hidden pattern in the data*: Requests for Quotation were frequently skipped or abandoned in favor of direct order creation.

Moreover, Purchase Order Creation was identified as a critical activity, having a high impact score, which was further consolidated when the results of the methodology's application to the available subgraph emerged. This finding, though expected to some extent due to its downstream position in the process, brought attention to previously overlooked vulnerabilities. Particularly, it showcased the high coupling of activities between systems A and B, and secondarily system C, *which would mandate the implementation of risk mitigation activities not only in the originally impacted system* to ensure the best chances for business continuity.

The analysis highlighted that approximately 20% of nodes exhibited a dependency impact exceeding 0.5, effectively flagging them as critical for risk mitigation. This automated prioritization introduced a data-backed framework for focusing mitigation efforts, significantly challenging the company's existing prioritization approach. For instance, activities like Invoices and Quotations, previously deemed essential to protect, ranked much lower in our analysis. Conversely, subliminal risks in activities such as Purchase Order Creation were elevated in importance.

In the second case study, our findings indicated minimal impact propagation between the analyzed subprocesses, a result initially counterintuitive but later confirmed by the Business Process Manager. This observation reflected the relative independence of the subprocesses, as corroborated by the graph structure. Despite this decoupling, Purchase Requisition once again ranked high, *pointing to inefficiencies in process timing*—specifically, the frequent placement of new orders immediately after completing older ones.

While non-critical activities in Case 2 exhibited lower dependency impacts compared to Case 1, the analysis still showed that around 30% of the Point-of-Interest (POI) event's impact propagated to these activities, signaling potential vulnerabilities. The results of Case 2 further demonstrated that this methodology can differentiate between activities of varying importance, as most activities presented a relatively lower dependency impact due to the lesser importance of the analyzed activity to the overall process.

In both cases, critical attack opportunities were highlighted at entry points, particularly Purchase Requisition, that could propagate disruptions to interconnected systems, notably the ERP system (System A). This was somewhat alarming to the stakeholders, as it *indicated overlap between the finalization of a process and the start of a new one, and indicated that a high degree of delays that had become normalized left them vulnerable to disproportionate disruption in the case of an attack*. These findings emphasized our

methodology's ability to detect nuanced dependencies and provide actionable insights for prioritizing mitigation efforts, complementing traditional BIA methodologies.

The interviews in general reinforced this methodology's ability to uncover nuanced insights, align with business realities, and enhance risk mitigation prioritization. Its data-driven approach provided clarity on critical dependencies while challenging conventional assumptions, making it a valuable complement to traditional BIA methods.

5.3.2 Conclusions from the interview process

Employee feedback consistently highlighted the methodology's unique ability to provide insights that were not achievable through traditional methods. The contributions observed were particularly significant in two areas:

1. Revealing discrepancies between expected and actual system use, prompting adjustments to contingency plans and security measures.
2. Identifying correlations or loosely connected activities and assets that require integrated risk management but are not evident in high-level BIA modeling.

For example, the Procurement Officer and Process Manager confirmed several insights as expected, but these details were not available to those responsible for system maintenance and security assurance. Such insights were only made possible through the use of process mining. The company had not previously leveraged its system activity logs for process mining, relying instead on traditional Business Process Management (BPM) techniques. The presented methodology revealed discrepancies between theoretical process models and actual process execution, a common challenge in many organizations. These non-conforming aspects, uncovered by our approach, reflected the real state of operations, emphasizing the importance of adjusting plans and contingencies to address these discrepancies.

The organization was advised and committed to reassess its processes after eliminating the identified discrepancies, ensuring future models accurately represent actual practices.

5.3.3 Baseline analysis

From the identified body of related work, several broad categories emerge as established methods that can serve as baselines for evaluating our methodology and comparing its performance. These categories, along with the insights on their comparison with our methodology gleaned from the interviews, are presented in the following paragraphs.

5.3.3.1 Traditional business impact analysis (BIA) methods

Standard methodologies in this area, such as ISO 22317 [2,

p. 22] and NIST 8286D [16] can be applied to the same use cases as the presented methodology. Their results can then be compared to those produced by our methodology to assess its effectiveness and novel contributions. The company that provided the use case is indeed ISO 22317 compliant, and so their existing Business Impact Analysis and strategy was referenced throughout the interviews.

The following key differences were identified:

1. The reconstruction of the business processes from the event logs by our methodology allowed for a much more accurate snapshot of the organization, as the BIA was based on a theoretical process model that was not sufficiently updated. Particularly, the change of vendors for systems B and D, that had occurred in the year prior, which theoretically should not have altered the processes, was found to have actually inserted tiny incremental changes to how these systems are used and interacted with the whole ecosystem.
2. The existing risk mitigation strategy based on the existing BIA was highly focused on the different systems used in the procurement process, as those were theoretically used to perform different functionalities/subprocesses that theoretically are decoupled from one another. However, the reality as uncovered in this case study, was that there was a much higher degree of connection between certain activities and many more back-and-forths between systems than expected based on theoretical models, which rendered the existing strategy less effective.
3. The existing BIA failed to account for the way users implemented the process, which often diverged from the designed model, in ways that were not documented at all by the organization and which over time became the norm, rendering several assumptions of the analysis irrelevant.

5.3.3.2 Process mining techniques for dependency graph generation Methods that construct dependency graphs without incorporating a risk management perspective, can be applied to identical event logs. For this purpose, a variation of our methodology was created where it accepted as weights the ones generated by the methodology presented in [58], rather than the ones proposed in this paper, and consequently applied PRIA's algorithm [1]. The results generated for the first case showed minimal variation, with all impact values calculated falling within a [0.3,0.4] window, as presented in Table 7.

The alternative ranking produced in this manner, was found to be of little value, as it didn't generate a significant variation to create a robust ranking of activities. When assessed by the experts, it was found to be of little value to them, aside from the graph itself.

Table 7 Comparison of the ranking of activities based on calculated dependency impact, with activity "B_Create Purchase Requisition" as POI event, using weights derived with and without the features proposed by our methodology

Activity	Dependency Impact (this paper)	Dependency Impact (alternative)
B_Create Purchase Requisition	1	1
A_Release Purchase Requisition	0,8356	0.3251
A_Create Purchase Order	0,7472	0.3834
A_Change Order Payment Terms	0,5523	0.3978
A_Change Order Storage Location	0,519	0.3075
C_Update Order Confirmation	0,5001	0.3583
C_Receive Order Confirmation	0,4996	0.305
A_Change Order Quantity	0,4542	0.358
A_Change Approval for Purchase Order	0,4497	0.3335
D_Block Supplier Invoice	0,4461	0.3963
A_Register Order Delivery	0,4327	0.3417
A_Delete Purchase Order	0,4272	0.3072
A_Cancel Goods Receipt	0,427	0.3141
D_Block subsequent invoices	0,4223	0.3052
A_Change Order Price	0,4135	0.3692
C_Record Quotation	0,4125	0.3491
B_Record Goods Receipt	0,4062	0.3177
A_Reject Order	0,3969	0.3736
A_Create Request for Quotation	0,3927	0.3554
A_Release Purchase Order	0,392	0.3924
D_Register supplier debit memo	0,3855	0.3928
A_Change Order Currency	0,3827	0.3005
D_Register supplier invoice	0,3782	0.3465
D_Record Invoice Receipt	0,375	0.3156

Table 7 (continued)

Activity	Dependency Impact (this paper)	Dependency Impact (alternative)
A_Cancel Subsequent Invoice	0,3683	0.3608
D_Record Subsequent Invoice	0,3634	0.3358
A_Cancel Invoice Receipt	0,3592	0.3251
D_Clear Invoice	0,3589	0.3834
D_Remove Payment Block	0,3473	0.3978
D_Set Payment Block	0,3446	0.3070

5.3.3.3 Impact propagation techniques in alternative contexts

Techniques developed for purposes other than business impact analysis, such as for attack investigation, utilize algorithms akin to the one developed for this methodology. These can be employed as benchmarks to evaluate its algorithmic performance and its results in the context of impact propagation.

For this purpose, the algorithm presented in [48] which bears similarities to the one employed by our methodology, was implemented and applied to our graph, once the weights had been calculated. However, no results were generated, and thus weren't presented in the interview process, as the algorithm failed to terminate, and we observed the impact assigned to each activity get progressively bigger at each iteration.

The reason for this occurrence is that this algorithm, as is the case for many similar algorithms addressing such problems, is designed for graphs depicting events that happen only in sequence, not accounting for the possibility that closed loops within them exist. In process mining, conversely, that is the basis of our methodology, it is very probable that closed loops will exist, as business processes often include repetitions of sub-sequences, and the employed algorithm correctly addresses this issue.

5.3.4 Performance and scalability

In all tests, the presented methodology generated results in under a minute on a standard desktop setup. The algorithm's iterations ranged from a few hundred to several thousand, depending on the complexity of the Point-of-Interest (POI) node and its associated paths. Most execution time (90–95%) was devoted to process mining and graph generation, with the impact propagation algorithm requiring only a minor portion of the overall runtime.

This efficiency suggests that, in practical use, the graph could be generated once and reused, with the propagation algorithm applied dynamically for each scenario. Its scalability was also assessed in the context of:

1. Handling large organizational event logs.
2. Generating graphs for multiple processes by applying process mining separately to each and connecting sub-graphs at common points.
3. Applying the algorithm to larger, more complex graphs.

Commercial process mining tools provide strategies for handling large datasets. Creating subgraphs for each process could simplify the analysis and minimize overlap, keeping the propagation within smaller subgraphs and ensuring efficient execution.

6 Conclusion

This paper expands on PRIA, first introduced in [1], a methodology for modeling business processes as weighted graphs to analyze the propagation of cybersecurity incident impact. By leveraging concepts from process mining, causality analysis, attack investigation, and risk management, our methodology identifies critical activities and pathways, reducing the graph to its essential components to prioritize risk mitigation.

The methodology presented in this paper calculates edge weights using features that emphasize transitions likely to propagate high impact. It includes an algorithm to trace impact propagation through the graph, identifying vulnerabilities without relying on predefined assumptions, enabling flexible modeling of scenarios such as external breaches.

A tool integrating open-source process mining software with custom modules was developed to implement this approach. This tool generates business dependency graphs, computes weights, applies the propagation algorithm, and extracts critical nodes. Results were computed in under a minute on standard hardware, with most time spent on graph generation, demonstrating its scalability for large datasets.

Validation using a real-world dataset and expert interviews confirmed its effectiveness in identifying critical activities and revealing hidden interdependencies. It highlighted overlooked risks and deviations between theoretical and actual process models, offering insights for updating outdated models and optimizing processes.

Based on our case studies, our methodology offers advantages over traditional Business Impact Analysis (BIA) methods by automating processes, significantly reducing assessment time, and providing enhanced, activity-specific insights into how, why, and by whom assets are used. It

enables attack vector modeling to identify potential infection paths and vulnerabilities while delivering actionable insights for prioritizing risk mitigation and adapting recovery strategies. By integrating process-aware methodologies, this methodology not only enriches risk management practices but also enhances the robustness and adaptability of cybersecurity strategies, making it a valuable tool for strengthening organizational resilience against cyber threats.

6.1 Restrictions and future work

The proposed approach has limitations. It depends on event logs, which means that activities occurring outside of the logged information systems are not considered. Although the results are generated automatically, they must still be linked to underlying assets for proper integration into the organization's cybersecurity plan. The impact calculated in this methodology is relative to the initial POI event and should be compared with absolute values from a traditional BIA for a comprehensive analysis. Additionally, while process mining techniques are optimized for individual processes, real-world scenarios often require the analysis of multiple processes across various logs.

Future work should focus on scaling this methodology to cover all active processes within an organization and exploring ways to integrate risk assessment components that incorporate business process concepts. This would facilitate the development of end-to-end automated risk management solutions. Additionally, options for automating the correlation of business processes with assets would greatly enhance its usefulness and further reduce the time needed to generate results. Finally, the threat model could be expanded to incorporate all possible attack scenarios presented in this paper.

Author contribution MR, GS and DG wrote the main manuscript text. MR prepared figures and graphs. GS and DG reviewed the manuscript.

Funding Open access funding provided by HEAL-Link Greece.

Data availability No datasets were generated or analysed during the current study.

Declarations

Conflict of interest The authors declare no competing interests.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will

need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

1. Raptaki, M., Stergiopoulos, G., Gritzalis, D.: Automated event log analysis with causal dependency graphs for impact assessment of business processes. *IEEE Access* **12**, 194322–194339 (2024). <https://doi.org/10.1109/ACCESS.2024.3520420>
2. ISO/TS 22317:2021, Security and resilience — business continuity management systems — guidelines for business impact analysis, 2021
3. NIST SP, Managing information security risk: organization, mission, and information system view. National Institute of Standards and Technology, Gaithersburg, MD, NIST SP 800–39, 2011. <https://doi.org/10.6028/NIST.SP.800-39>
4. Syalim, A., Hori, Y., Sakurai, K.: Comparison of risk analysis methods: mehari, magerit, NIST800–30 and microsoft's security management guide. In 2009 International Conference on Availability, Reliability and Security, Fukuoka, Japan: IEEE, 2009, pp. 726–731. <https://doi.org/10.1109/ARES.2009.75>
5. Xu, L.D., Xu, E.L., Li, L.: Industry 4.0: state of the art and future trends. *Int. J. Prod. Res.* **56**(8), 2941–2962 (2018). <https://doi.org/10.1080/00207543.2018.1444806>
6. Schulte, S., Janiesch, C., Venugopal, S., Weber, I., Hoenisch, P.: Elastic business process management: state of the art and open challenges for BPM in the cloud. *Future Gener. Comput. Syst.* **46**, 36–50 (2015). <https://doi.org/10.1016/j.future.2014.09.005>
7. Tupa, J., Steiner, F.: Industry 4.0 and business process management. *Teh. Glas.* **13**(4), 349–355 (2019). <https://doi.org/10.31803/tg-20181008155243>
8. Van Der Aalst, W.: *Process Mining*. Berlin, Heidelberg: Springer Berlin Heidelberg, 2016. <https://doi.org/10.1007/978-3-662-49851-4>
9. Caron, F., Vanthienen, J., Baesens, B.: A comprehensive investigation of the applicability of process mining techniques for enterprise risk management. *Comput. Ind.* **64**(4), 464–475 (2013). <https://doi.org/10.1016/j.compind.2013.02.001>
10. Kelemen, R.: Systematic review on process mining and security. *Cent. East. Eur. EDem EGov Days* **325**, 145–164 (2018). <https://doi.org/10.24989/ocg.v325.13>
11. Suriadi, S., et al.: Current research in risk-aware business process management—overview, comparison, and gap analysis. *Commun. Assoc. Inf. Syst.*, **34**, (2014). <https://doi.org/10.17705/1C AIS.03452>
12. Tjoa, S., Jakoubi, S., Quirchmayr, G.: Enhancing business impact analysis and risk assessment applying a risk-aware business process modeling and simulation methodology. In 2008 third international conference on availability, reliability and security, IEEE, pp. 179–186 (2008). <https://doi.org/10.1109/ARES.2008.206>
13. Caron, F., Vanthienen, J., Baesens, B.: Comprehensive rule-based compliance checking and risk management with process mining. *Decis. Support. Syst.* **54**(3), 1357–1369 (2013). <https://doi.org/10.1016/j.dss.2012.12.012>
14. Dedousis, P., Raptaki, M., Stergiopoulos, G., Gritzalis, D.: Towards an automated business process model risk assessment: a process mining approach. In: Proceedings of the 19th international conference on security and cryptography, Lisbon, Portugal: SCITEPRESS - Science and Technology Publications, pp. 35–46 (2022). <https://doi.org/10.5220/0011135600003283>
15. Stine, K., Quinn, S., Witte, G., Gardner, R.K.: Integrating cybersecurity and enterprise risk management (ERM). *Natl Inst Stand Technol* (2020). <https://doi.org/10.6028/NIST.IR.8286>

16. Quinn, S., et al.: Using business impact analysis to inform risk prioritization and response. National institute of standards and technology (U.S.), Gaithersburg, MD, NIST IR 8286D, (2022). <https://doi.org/10.6028/NIST.IR.8286D>
17. Burton, S. L., Protection via business impact analysis in a cyber world: A 3-part series. In 17th international conference on information technology—new generations (ITNG 2020), vol. 1134, S. Latifi, Ed., in Advances in Intelligent Systems and Computing, vol 1134, pp 3–8, Cham, Springer International Publishing (2020). https://doi.org/10.1007/978-3-030-43020-7_1
18. Strelitz, A., Bognár, F.: Integrated risk and business impact analysis: a kind of support for ISO 22301. Eur. Sci. J. ESJ (2020). <https://doi.org/10.19044/esj.2020.v16n4p1>
19. Torabi, S.A., Rezaei Soufi, H., Sahebjamnia, N.: A new framework for business impact analysis in business continuity management (with a case study). Saf. Sci. **68**, 309–323 (2014). <https://doi.org/10.1016/j.ssci.2014.04.017>
20. Kotzanikolaou, P., Theoharidou, M., Gritzalis, D.: Assessing n-order dependencies between critical infrastructures. Int. J. Crit. Infrastruct. **9**(1–2), 93–110 (2013)
21. Stergiopoulos, G., Kouktzoglou, V., Theocharidou, M., Gritzalis, D.: A process-based dependency risk analysis methodology for critical infrastructures. Int. J. Crit. Infrastruct. **13**(2/3), 184 (2017). <https://doi.org/10.1504/IJCIS.2017.088231>
22. Al-Essa, H. A., Al-Sharidah, A. H.: An approach to automate business impact analysis. In: 2018 IEEE international systems engineering symposium (ISSE), Rome: IEEE, 2018, pp 1–3. <https://doi.org/10.1109/SysEng.2018.8544438>
23. Sikdar, P.: Alternate approaches to business impact analysis. Inf. Secur. J. Glob. Perspect. **20**(3), 128–134 (2011). <https://doi.org/10.1080/19393555.2010.551274>
24. Bartolini, C., Stefanelli, C., Tortonesi, M. Business-impact analysis and simulation of critical incidents in IT service management. In: 2009 IFIP/IEEE international symposium on integrated network management, New York, NY, USA: IEEE, pp. 9–16 (2009). <https://doi.org/10.1109/INM.2009.5188781>
25. Radeschütz, S., Schwarz, H., Niedermann, F.: Business impact analysis—a framework for a comprehensive analysis and optimization of business processes. Comput. Sci. - Res. Dev. **30**(1), 69–86 (2015). <https://doi.org/10.1007/s00450-013-0247-3>
26. Setzer, T., Bhattacharya, K., Ludwig, H.: Change scheduling based on business impact analysis of change-related risk. IEEE Trans. Netw. Serv. Manag. **7**(1), 58–71 (2010). <https://doi.org/10.1109/TNSM.2010.19P0305>
27. Stergiopoulos, G., Dedousis, P., Gritzalis, D.: Automatic analysis of attack graphs for risk mitigation and prioritization on large-scale and complex networks in Industry 4.0. Int. J. Inf. Secur. **21**(1), 37–59 (2022). <https://doi.org/10.1007/s10207-020-00533-4>
28. Adamos, K., Stergiopoulos, G., Karamousadakis, M., Gritzalis, D.: Enhancing attack resilience of cyber-physical systems through state dependency graph models. Int. J. Inf. Secur. (2023). <https://doi.org/10.1007/s10207-023-00731-w>
29. Huang, X., Vodenska, I., Havlin, S., Stanley, H.E.: Cascading failures in bi-partite graphs: model for systemic risk propagation. Sci. Rep. **3**(1), 1219 (2013). <https://doi.org/10.1038/srep01219>
30. Lykou, G., Dedousis, P., Stergiopoulos, G., Gritzalis, D.: Assessing interdependencies and congestion delays in the aviation network. IEEE Access **8**, 223234–223254 (2020). <https://doi.org/10.1109/ACCESS.2020.3045340>
31. Trieu-Do, V., Garcia-Lebron, R., Xu, M., Xu, S., Feng, Y.: Characterizing and leveraging granger causality in cybersecurity: framework and case study. ICST Trans. Secur. Saf. **7**(25), 169912 (2021). <https://doi.org/10.4108/eai.11-5-2021.169912>
32. Maiti, R. R., Adep, S., Lupu, E.: ICCPS: impact discovery using causal inference for cyber attacks in CPSs. 2023. *arXiv*. <https://doi.org/10.48550/ARXIV.2307.14161>
33. Myers, D., Suriadi, S., Radke, K., Foo, E.: Anomaly detection for industrial control systems using process mining. Comput. Secur. **78**, 103–125 (2018). <https://doi.org/10.1016/j.cose.2018.06.002>
34. ICT systems security and privacy protection: New York. Springer, Berlin Heidelberg, NY (2017)
35. Gongada, T.N., et al.: Leveraging machine learning for enhanced cyber attack detection and defence in big data management and process mining. Int. J. Adv. Comput. Sci. Appl. (2024). <https://doi.org/10.14569/IJACSA.2024.0150266>
36. Macak, M., Vanat, I., Merjavy, M., Jevocin, T., Buhnova, B.: Towards process mining utilization in insider threat detection from audit logs. In: 2020 seventh international conference on social networks analysis, management and security (SNAMS), Paris, France: IEEE, pp. 1–6. (2020). <https://doi.org/10.1109/SNAMS52053.2020.9336573>
37. Turner, R. C.: Process mining for asymmetric cybersecurity audit. In: 2022 IEEE International Conference on Cyber Security and Resilience (CSR), Rhodes, Greece: IEEE, pp. 293–298. (2022). <https://doi.org/10.1109/CSR54599.2022.9850298>
38. Khan, M. A., Pradhan, S. K., Fatima, H. Applying data mining techniques in cyber crimes. In 2017 2nd International Conference on Anti-Cyber Crimes (ICACC), Abha, Saudi Arabia: IEEE, pp. 213–216. (2017). <https://doi.org/10.1109/Anti-Cybercrime.2017.7905293>
39. Macak, M., Oslejsek, R., Buhnova, B.: Applying process discovery to cybersecurity training: an experience report. In: 2022 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), Genoa, Italy: IEEE, pp. 394–402. (2022). <https://doi.org/10.1109/EuroSPW55150.2022.00047>
40. Hemmer, A., Badonnel, R., Chrisment, I.: A process mining approach for supporting IoT predictive security. In: NOMS 2020–2020 IEEE/IFIP Network Operations and Management Symposium, Budapest, Hungary: IEEE, pp. 1–9. (2020). <https://doi.org/10.1109/NOMS47738.2020.9110411>
41. Pery, A., Rafiei, M., Simon, M., Van Der Aalst, W. M. P.: Trustworthy artificial intelligence and process mining: challenges and opportunities. In: Process Mining Workshops, vol. 433, J. Munoz-Gama and X. Lu, Eds., in Lecture Notes in Business Information Processing, vol. 433, Cham: Springer International Publishing, pp. 395–407. (2022). https://doi.org/10.1007/978-3-030-98581-3_29
42. Van Der Aalst, W., Weijters, T., Maruster, L.: Workflow mining: discovering process models from event logs. IEEE Trans. Knowl. Data Eng. **16**(9), 1128–1142 (2004). <https://doi.org/10.1109/TKDE.2004.47>
43. Giuseppe, C., Valerio, M., Teresa, M., Carmela, S.L.: A simulation approach in process mining conformance analysis. The introduction of a brand new BPMN element. IERI Procedia **6**, 45–51 (2014). <https://doi.org/10.1016/j.ieri.2014.03.008>
44. Althuhov, O., Matulevičius, R., Ahmed, N.: An extension of business process model and notation for security risk management. Int. J. Inf. Syst. Model. Des. **4**(4), 93–113 (2013). <https://doi.org/10.4018/ijismd.2013100105>
45. Cardoso, P., Respício, A., Domingos, D.: riskaBPMN - a BPMN extension for risk assessment. Procedia Comput. Sci. **181**, 1247–1254 (2021). <https://doi.org/10.1016/j.procs.2021.01.324>
46. Marcinkowski, B., Kuciapski, M.: A business process modeling notation extension for risk handling. In: Computer Information Systems and Industrial Management, A. Cortesi, N. Chaki, K. Saeed, and S. Wierzchoń, Eds., in Lecture Notes in Computer Science, vol. 7564, pp. 374–381. Berlin, Heidelberg: Springer Berlin Heidelberg (2012). https://doi.org/10.1007/978-3-642-33260-9_32
47. Meland, P. H., Gjaere, E. A.: Representing threats in BPMN 2.0. In: 2012 Seventh International Conference on Availability, Reliability

- and Security, Prague, TBD, Czech Republic: IEEE, pp. 542–550. (2012). <https://doi.org/10.1109/ARES.2012.13>
48. Fang, P., et al.: Back-propagating system dependency impact for attack investigation. In: Proceedings of the 31th USENIX Security Symposium, pp. 2461–2478. Boston, USA: USENIX Association (2022)
 49. Van Dongen, B. F., De Medeiros, A. K. A., Verbeek, H. M. W., Weijters, A. J. M. M., Van Der Aalst, W. M. P.: The ProM framework: a new era in process mining tool support. In Applications and Theory of Petri Nets 2005, G. Ciardo and P. Darondeau, Eds., In: Lecture Notes in Computer Science, vol. 3536, pp. 444–454. Berlin, Heidelberg: Springer Berlin Heidelberg (2005). https://doi.org/10.1007/11494744_25
 50. IEEE. IEEE 1849–2016 XES Standard. XES. [Online]. Available: <https://xes-standard.org>
 51. Van Der Aalst, W.M.P., Weijters, A.J.M.M.: Process mining: a research agenda. *Comput. Ind.* **53**(3), 231–244 (2004). <https://doi.org/10.1016/j.compind.2003.10.001>
 52. Van Der Aalst, W.: Process mining. *Commun. ACM* **55**(8), 76–83 (2012). <https://doi.org/10.1145/2240236.2240257>
 53. Van Dongen, B. F., Alves De Medeiros, A. K., Wen, L.: Process mining: overview and outlook of petri net discovery algorithms. In Transactions on Petri Nets and Other Models of Concurrency II, K. Jensen and W. M. P. Van Der Aalst, Eds., in Lecture Notes in Computer Science, vol. 5460, pp. 225–242. Berlin, Heidelberg: Springer Berlin Heidelberg (2009). https://doi.org/10.1007/978-3-642-00899-3_13
 54. Gunther, C. W., Verbeek, H. M. W.: XES - standard definition. BPMcenter. org, Vol. 1409
 55. Verbeek, H. M. W., Buijs, J. C. A. M., Van Dongen, B. F., Van Der Aalst, W. M. P.: XES, XESame, and ProM 6. In: Progress in Pattern Recognition, Image Analysis, Computer Vision, and Applications, E. Bayro-Corrochano and E. Hancock, Eds., in Lecture Notes in Computer Science, vol. 8827, pp. 60–75. Cham: Springer International Publishing (2011). https://doi.org/10.1007/978-3-642-17722-4_5
 56. Verbeek, H. M. W., Buijs, J. C. A. M., Dongen, van, B. F., Aalst, van der, W. M. P.: ProM 6 : the process mining toolkit. In Proceedings of the Business Process Management 2010 Demonstration Track (Hoboken NJ, USA, September 14–16, 2010), in CEUR Workshop Proceedings. CEUR-WS.org, pp. 34–39 (2010)
 57. Günther, C. W., Van Der Aalst, W. M. P.: A generic import framework for process event logs. In: Business Process Management Workshops, J. Eder and S. Dustdar, Eds., In Lecture Notes in Computer Science, vol. 4103, pp. 81–92. Berlin, Heidelberg: Springer Berlin Heidelberg (2006). https://doi.org/10.1007/11837862_10
 58. Verbeek, H.M.W., Van der Aalst, W.M.P., Munoz-Gama, J.: Divide and conquer: a tool framework for supporting decomposed discovery in process mining. *Comput. J.* **60**(11), 1649–1674 (2017). <https://doi.org/10.1093/comjnl/bxx040>

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.